

G-IBE Integration Profile – Combined Credential and Platform bound Enforcement (CCPE-G)

Abstract

The seventh integration pattern within the Combined Credential- and Platform-Bound Enforcement (CCPE) family named G-IBE, the Identity-Bound Enforcement profile. This RFC defines how GAuth integrates with identity-bound IAM platforms - IAM platforms that issue an agent-as-first-class identity object inside an enterprise directory and that bind the agent's authority to act on behalf of a principal to the attributes, entitlements, and lifecycle state of that identity object.

The architectural pattern this RFC names - “identity = mandate”, in shorthand - is the structural posture taken by a wide and growing set of identity-bound IAM platforms. This RFC is the engine-neutral integration profile for that pattern. It specifies

- a) the architectural model of identity-bound enforcement and the four boundary primitives at which the IAM platform's authority surface is exposed;
- b) the four normative non-conformant variants NCI / NCP / NCO / NCM;
- c) the bridge contract by which a CCPE-G deployment derives a synthetic CCPE-A/B/F-shaped mandate envelope from identity attributes plus a recorded principal-delegation event;
- d) the audit-trail invariants under the catalogue-and-prescribe posture of §3.0;
- e) the four governance-profile categories Minimal / Standard / Strict / Platform-Native;
- f) the Preliminary Microsoft Entra Agent ID Cookbook (Appendix A) and the Preliminary Cookbooks for Okta + Auth0 (B), Ping + ForgeRock (C), SPIFFE/SPIRE-with-layered-principal-delegation (D), and CyberArk + Venafi (E); and
- g) the GAuth Open-Core Reference Connector Slot Registry of §13.A.

Central thesis: A credential-bound identity is not the same as a credential-bound authority. Identity-bound enforcement, taken on its own, does not yet meet the state-of-the-art PoA-protocol bar set by GiFo-RFC 0117's Power-PEP pipeline operating on a GiFo-RFC 0115 PoA Credential. A pure identity bound mandate does not necessarily comply with the EU AI Act`s requirements.

Identity-based authentication establishes that an agent is registered and that its credential is valid; it does not establish, on a per-action basis, who the natural-person principal is, what scope the action falls within, what consent the principal gave, what evidence was used, or how the action can be revoked or overridden. The EU AI Act's Articles 12, 13, 14, 15, 26, and 27 require precisely those per-action, per-principal, evidentiary properties. Pure identity-based enforcement, deployed in isolation against any AI Act high-risk use-case, cannot generate the evidentiary record the regulator will ask for.

CCPE-G's contribution, therefore, is to bring both angles together in a single deployable architecture: Phase 1 - GAuth's credential-bound authority enforcement (mandate / PoA Credential / 16-check Power-PEP) - combined with Phase 2 - the IAM platform's identity-platform-bound authentication enforcement (Conditional Access / authorization-server / workload-attestation). The bridge contract of §6 is the central operational mechanism (not a sidecar) by which Phase 2 hands a derived synthetic mandate to Phase 1 at every action class governed by §6.2's trigger conditions; a Phase-2-only deployment that omits the bridge Should not claim CCPE-G conformance above the Minimal profile of §8.1. The full Phase-1 / Phase-2 architectural statement is §3.0.

This RFC refers to Apache 2.0 together with the legal terms of Gimel Foundation. The RFC inherits three Exclusions (AI-Enabled Governance, Web3, DNA-based ID / PQC), in line with the legal terms.

Status of This Memo — Working Draft

This document is published as a working draft, Standards Track.

The document is open to community review and to vendor feedback. Corrections via §18.

Legal Notice

Copyright (c) 2026 Gimel Foundation and the persons identified as the document authors. All rights are reserved.

This document is subject to GiFo-RFC 0080 (Legal Provisions Relating to GiFo Documents), GiFo-RFC 0090 (Rights in Contributions), and GiFo-RFC 0100 (Intellectual Property Rights Policy) in effect on the date of publication of this document.

This specification is published under the Apache License 2.0, consistent with GiFo-RFCs 0110, 0111, 0115, 0116, 0117, 0118, 0125, 0130, 0140, 0150, 0160, 0170, 0180, and 0420. For this RFC, any AI enabled Governance support, Web3 integration as well as DNA-based identity / PQC is excluded. Such Exclusions apply in line with Gimel Foundation`s Legal Terms GiFo-RFC 0080 - 0100. Patents are pending.

Trademark Notice. Product names, trademarks, and registered trademarks referenced in this document are the property of their respective owners and are used here for descriptive identification purposes only under nominative fair use principles. No endorsement, sponsorship, partnership, or affiliation is implied.

Notational Conventions

The key words "Must", "Must Not", "Required", "Shall", "Shall Not", "Should", "Should Not", "Recommended", "May", and "Optional" in the following specification are to be interpreted as described in IETF RFC 2119. These key words appear in cap-first form throughout the document.

RFC 2119 keywords appear in this document in initial-capital form (Must, Should, May, Must Not, Should Not). The semantic force is identical to the all-uppercase form; the typographic choice follows Foundation editorial convention across the GiFo-RFC 0140 family.

Note on terminology - Power*Point vs. Policy*Point. GiFo-RFCs 0110 and 0111 normatively define P*P in the GAuth context as Power Decision / Enforcement / Administration / Information / Verification Point, intentionally distinct from the XACML / IETF RFC 2753 sense of P*P as Policy*Point. RFC 0210 follows the family convention: GAuth components are Power-* by definition; CCPE-G runtime-enforcement components are designated Identity-* to mark the seventh axis (identity-platform-bound, distinct from policy-bound, communication-substrate-bound, developer-tooling-bound, AloT-substrate-bound, and commerce-substrate-bound).

Parallel-naming-convention paragraph. This RFC reserves the audit-trail ``phase2_evaluation.profile`` value namespace prefix ``ccpe-g-*``. The base value ``ccpe-g`` denotes a CCPE-G-conformant Phase-2 evaluation; non-conformant variants are designated ``ccpe-g-nci`` / ``ccpe-g-ncp`` / ``ccpe-g-nco`` / ``ccpe-g-ncm`` per §3.4.

Table of Contents

1. Scope
2. Terminology
3. Background and Integration Architecture
4. The Identity-as-Authority Object Model
5. Pre-Action Enforcement Surface
6. Bridge Contract — CCPE-G → CCPE-A / CCPE-B / CCPE-F
7. Revocation and Lifecycle
8. Governance Profile Categories
9. Module / Practice Taxonomy
10. Governance Event Schema
11. Conformance
12. Security Considerations
13. Implementation Guidance
14. Scope vs. Conformance
15. IANA / Registry Reservations
16. Cross-RFC Anchors
17. References (incl. §17.1 Standards-Body Coordination Posture)
18. Correction Channel
19. Open Issues

Appendixes

- Appendix A — Microsoft Entra Agent ID Cookbook
- Appendix B — Okta + Auth0 + Token Vault Cookbook (Preliminary)
- Appendix C — Ping Identity / PingOne / ForgeRock Cookbook (Preliminary)
- Appendix D — SPIFFE / SPIRE with Layered Principal-Delegation Cookbook (Preliminary)
- Appendix E — CyberArk + Conjur + Venafi Cookbook (Preliminary)
- Appendix F — GAuth Open-Core SDK Reference Connector-Slot-Registry Foundation

1. Scope

1.1 What This RFC Does

This RFC specifies the CCPE-G Integration Profile for identity-bound IAM platforms. Specifically, it:

- a) Names and characterises the identity-bound enforcement architectural pattern (informally, “identity = mandate”) as a peer category within the CCPE family, sitting alongside the mandate-explicit CCPE-A through CCPE-F profiles.
- b) Defines the three-service architectural split (Directory / Authority-Surface / Runtime-PEP) by which an identity-bound deployment exposes the four boundary primitives at which the IAM platform's authority surface is observable, instrumentable, and bridgeable.
- c) Defines the non-conformant variant taxonomy NCI / NCP / NCO / NCM that classifies the four most common ways an identity-bound deployment leaves authority semantics incomplete.
- d) Defines the bridge contract (§6) by which a CCPE-G deployment derives a synthetic mandate envelope from identity attributes plus a recorded principal-delegation event.
- e) Defines the audit-event schema (§10) by which an identity-bound deployment emits a per-action event stream that lets downstream consumers reconstruct mandate-equivalent semantics post-hoc.
- f) Defines the four governance-profile categories Minimal / Standard / Strict / Platform-Native and the conformance-feature matrix.
- g) Specifies the (Preliminary) Cookbooks of Appendices A–E.
- h) Specifies the GAuth Open-Core Reference Connector Slot Registry foundation (§13.A and Appendix F): the multi-instance `identity\_platform` slot (Type-A) and the single `identity\_bridge` slot (Type-B).

1.2 What This RFC Does Not Do

- a) Replace, supersede, or modify the GAuth core protocol (RFCs 0110, 0111, 0115, 0117, etc.).
- b) Specify the credential format (DPoP, mTLS, X.509-SVID, JWT-SVID, ID-JAG, bearer access token) that a CCPE-G-conformant IAM platform Must use.
- c) Specify the directory schema by which an IAM platform Must encode the agent's authority.
- d) Address consumer-grade SSO without an enterprise-directory anchor.
- e) Address pure workload-identity deployments without a principal-delegation contract.
- f) Replace, supersede, or modify any of the mandate-explicit CCPE family members (CCPE-A through CCPE-F).

- g) Evaluate vendors, endorse, claim partnership, or warrant capabilities.

1.3 Relationship to Other Specifications

GiFo-RFC 0110 (GAuth Core Protocol) | Foundational. Power- nomenclature, principal-agent-sub-agent delegation model, protocol envelope inherited unchanged.

GiFo-RFC 0111 (Extended OAuth Tokens) | Foundational. Extended-OAuth-Token shape carries the synthetic mandate envelope of §6 to downstream consumers.

GiFo-RFC 0115 (PoA Credential Structure) | Target of the bridge contract (§6). The synthetic mandate envelope conforms to RFC 0115; §3.7 mandatory multi-hop scope-narrowing applies.

GiFo-RFC 0117 (GAuth PEP Interface) | Foundational. The 16-check pipeline is restated in identity-bound form in §5; PERMIT / DENY / CONSTRAIN preserved.

GiFo-RFC 0125 (GAuth Open-Core SDK) | Reference implementation. At v0.93+, the SDK includes the §13.A connector-slot-registry foundation: the multi-instance ``identity_platform`` slot and the single ``identity_bridge`` slot, with the tariff-matrix gates and the open-core symmetry rules of §6.5. MPL 2.0 + Foundation Additional Terms applies to SDK-derived code only.

GiFo-RFC 0130 (CCPE Pattern Catalogue) | Architectural anchor. CCPE-G extends the family taxonomy with the identity-bound peer category.

GiFo-RFC 0140 v1.2.1 (G-AGT, CCPE-A) | Family anchor. ``phase2_evaluation.profile`` field, parallel-naming convention, cross-RFC consistency discipline inherited. CCPE-A is the primary downstream consumer for agent-runtime-side handoff.

GiFo-RFC 0150 v0.9.6 (G-PaC, CCPE-B) | Family peer. CCPE-B is a downstream consumer for Policy-as-Code-engine handoff.

GiFo-RFC 0160 v0.6 (G-Com, CCPE-C) | Family peer. Inter-agent communication-substrate handoff naturally indirected through CCPE-A or CCPE-B.

GiFo-RFC 0180 v0.9 (CCPE-D) | Family peer. AI-coding-assistant-substrate handoff naturally indirected through CCPE-A.

GiFo-RFC 0200 (GiFo Identifier) | Sibling occupant of the GiFo-RFC 02xx Identity-platform-domain block.

GiFo-RFC 0420 v0.7 (G-IoT, CCPE-E) | Family peer. The constrained-audit-profile of RFC 0420 §6 is informatively comparable to bandwidth-constrained sub-cases.

IETF RFC 7523 (JWT) | Adjacent — wire-level credential-shape option.

IETF RFC 8693 (OAuth 2.0 Token Exchange) | Adjacent — XAA-aligned cross-app handoff.

IETF RFC 9396 (RAR) | Adjacent — natural carrier for the synthetic mandate envelope on the wire.

IETF RFC 9449 (DPoP) | Adjacent — sender-constrained-credential mechanism.

IETF draft-ietf-oauth-identity-assertion-authz-grant (XAA) | Adjacent — wire-level cross-app token-exchange profile. CCPE-G is the architectural-pattern profile above XAA.

IETF draft-klrc-aiagent-auth (AIMS) | Adjacent — agent-identity-and-delegation-chain framework.

NIST IR 8596 (Cyber AI Profile) | Adjacent. The L1 (pre-action enforcement) and L2 (multi-hop scope narrowing) leverage points apply to identity-bound deployments. The bridge contract of §6 is the operationalisation mechanism.

NIST SP 800-207 (Zero Trust) | Adjacent. CCPE-G's Identity-PEP is the identity-bound-deployment-shaped specialisation of the SP 800-207 PEP.

2. Terminology

For the purposes of this document, the following terms have the meanings given here. Terms not defined here retain their meaning from the cross-referenced specifications.

- Identity-Bound Enforcement - the architectural pattern in which the IAM platform's identity object for an agent is the carrier of the agent's authority to act on behalf of a principal.
- Identity-Bound IAM Platform - an enterprise IAM platform that issues an agent-as-first-class identity object inside an enterprise directory and binds the agent's authority to act to the attributes and lifecycle state of that identity object.
- Identity Object - the directory record for the agent. CCPE-G is engine-neutral with respect to schema.
- Boundary Primitive - one of the four observable platform-side operations: identity-issuance, identity-attribute-mutation, identity-revocation, identity-introspection. See §3.3.
- Synthetic Mandate - a GAuth-RFC-0115-shaped mandate envelope derived by the bridge contract (§6) from a CCPE-G identity object's attributes plus a recorded principal-delegation event.
- Native Mandate - a GAuth PoA Credential issued by a GAuth-native authority surface.
- Bridge Boundary - the defined point at which a CCPE-G deployment emits a synthetic mandate envelope. See §6.2.

- Identity-PEP - the CCPE-G-side runtime enforcement component running the 16-check pipeline of RFC 0117 against the agent's identity-attribute-encoded authority. See §5.1.
- Mandate-Mutation Event - a structured audit event emitted at any of the four boundary primitives that records a change in the agent's authority surface.
- Mandate-Mutation Tracking - the discipline of emitting a mandate-mutation event at every boundary primitive that changes the agent's authority surface, with sufficient detail to let a downstream consumer reconstruct the synthetic mandate envelope post-hoc.
- Catalogue-and-Prescribe - the editorial posture of this RFC: descriptive at the architectural shape, sharp at the PoA-conformance bar.
- Phase 1 / Phase 2 - the two-phase architectural framing of §3.0. Phase 1 is GAuth's credential-bound authority enforcement; Phase 2 is the IAM platform's identity-platform-bound authentication enforcement. Phase 2 alone is necessary but not sufficient for actions requiring PoA semantics.
- Connector Slot - a registered point in the GAuth open-core reference operator at which an external dependency is plugged in via a typed adapter interface. See §13.A.
- Slot Type - one of: Type-A (multi-instance), registered per-instance and identified by an externally-controlled identifier (e.g., per-platform-id); or Type-B (single-instance), where the registry holds at most one active adapter per slot. The 9-slot registry of §13.A holds 8 Type-B slots and 1 Type-A slot (``identity_platform``).
- Operator Mode - for each connector slot at each tier, one of: ``null_or_user``, ``user_provided_required``, ``user_self_hosted``, ``gimel_managed``, ``gimel_or_user``.
- Bridge Emission - a single invocation of the bridge contract of §6 that emits one synthetic mandate envelope.

Throughout this document, the term CCPE (Combined Credential- and Platform-Bound Enforcement) refers to the architectural family normatively introduced in GiFo-RFC 0140.

3. Background and Integration Architecture

3.0 Central Thesis — Identity Is Not Authority; Phase 1 and Phase 2 (Normative)

The central architectural claim of this RFC is sharp and load-bearing for every section that follows: a credential-bound identity is not the same as a credential-bound authority. A sender-constrained credential issued by an identity-bound IAM platform - an Entra-issued DPoP-bound access token, an Okta-issued JWT, an X.509-SVID, a JWT-SVID, an Auth0 Token-Vault token - cryptographically binds the credential to the agent's authenticated identity at the moment of issuance. It does not, on its own, bind the

credential to a power-of-attorney mandate: a structured, signed, scoped delegation document that names the principal, the subject, the allowed action set, the resource scope, the operating-window TTL, the multi-hop scope-narrowing chain, and the revocation handle per GiFo-RFC 0115.

Stated bluntly: identity-bound enforcement, on its own, does not yet meet the state-of-the-art PoA-protocol bar. The 16-check Power-PEP pipeline of GiFo-RFC 0117 §4 evaluates principal identity, allowed action set, multi-hop scope-narrowing chain, principal-consent validity, revocation freshness, and twelve other checks that an identity-bound credential cannot supply from its body alone. The four gaps are the four non-conformance dimensions catalogued in §3.4 (NCI / NCP / NCO / NCM).

CCPE-G's contribution is to bring the two angles together in a single deployable architecture. Two phases, run in series at the moment of action:

- 1) **Phase 1 - Credential-bound authority enforcement.** GAuth-native. A PoA Credential per RFC 0115, evaluated by the Power-PEP per RFC 0117 §4 (the 16-check pipeline) against the agent's requested action.
- 2) **Phase 2 - Identity-platform-bound authentication enforcement.** The IAM platform's existing surface (Conditional Access; Okta authorization servers + Universal Logout; Auth0 Actions + FGA + Token Vault; PingOne authorization policies; SPIRE Workload-API attestation; CyberArk + Venafi attestation).

The two phases run in series. Phase 2 first; Phase 1 second, on the Phase-2 output.

Phase 2 alone is necessary but not sufficient for any action requiring PoA semantics.

The bridge contract of §6 is therefore not a sidecar or an interoperability nicety. It is the central operational mechanism by which a Phase-2-only identity-bound deployment becomes Phase-1+Phase-2 PoA-conformant. A deployment that omits the bridge - a Phase-2-only deployment - does not meet the CCPE-G bar for any action class governed by §6.2's trigger conditions and Should not claim CCPE-G conformance above the Minimal profile of §8.1.

Phase-2 check-count framing — precise. Of the 16 checks in the GiFo-RFC 0117 §4 Power-PEP pipeline, Phase 2 supplies 1–3 checks in conformant operation: check 1 (agent identity binding / cnf-claim authentication) directly; one or two further checks tied to platform-side policy-compliance evaluation. Phase 1 retains the substantive 13–15 checks (principal-delegation provenance, allowed-action-set evaluation, multi-hop scope-narrowing per RFC 0115 §3.7, principal-consent-provenance sufficiency, operating-window TTL, revocation freshness, scope-chain narrowing invariants, etc.). Phase 1 is leading in importance; Phase 2 is leading in time.

3.0a Deployment Scenarios — S1 / S2 / S3 (Normative)

A CCPE-G-relevant deployment falls into one of three scenarios, all in scope of this RFC. Scope and conformance are distinct dimensions (see §14).

3.0a.1 S1 — Pure Phase-2-Only Deployment

The IAM platform's native authority surface alone. No Foundation-derived synthetic PoA Credential; no §6 bridge invocation; no §10 audit-event schema. S1 is non-conformant to Standard / Strict / Platform-Native; May be declared at Minimal only.

Foundation IP touchpoints. None at the spec-implementation layer. S1 may still touch Foundation IP indirectly: NCI / NCP / NCO / NCM taxonomy; Phase-1 / Phase-2 terminology; identity-bound enforcement term-of-art.

3.0a.2 S2 — §6 Bridge (Two-Artifact Architecture, Recommended)

The IAM platform's identity-bound credential continues at Phase 2; a second Foundation-derived artefact - the synthetic mandate envelope of §6.1 - is constructed by the bridge contract from identity attributes plus the recorded principal-delegation event. Two operational coupling patterns at the bridge boundary:

- (a) co-delivered (synthetic mandate transmitted alongside the identity-bound credential, e.g., as an additional JWT under `Accept: application/vnd.gimel.gauth.poa+jwt`); or
- (b) by-reference (identity-bound credential carries a `bridge\_evidence` reference to a synthetic mandate held in a Foundation-side bridge service that the downstream dereferences on receipt).

S2 is the conformant scenario for Standard / Strict / Platform-Native.

3.0a.3 S3 — All-in-One Merged-Credential Deployment

The IAM platform extends its native identity-bound credential format with PoA-shape attributes (principal, allowed_actions, scope, expiry, delegation_chain) inside the same credential body. S3 is non-conformant to Standard / Strict / Platform-Native; structural reasons catalogued at §3.1.1.

If five enumerated conditions (audit-event schema at the four boundary primitives; discrete principal-delegation event cryptographically referenced; multi-hop scope-narrowing honoured; revocation handle decoupled from credential lifecycle; §6.2 trigger-condition mechanics for cross-family interoperability) are all met, the deployment becomes S2-by-another-name and may be reclassified.

3.1 Why a Standalone Spec — Architectural Deltas vs. the Mandate-Explicit CCPE Family

Four architectural deltas justify a standalone profile:

- **Delta 1 - The credential carries identity, not authority.** A mandate-explicit credential carries the principal-to-agent delegation directly in the credential body. An identity-bound credential carries the agent's identity and its current attribute state at issuance time; authority is encoded as identity attributes on the directory record.
- **Delta 2 — Authority mutates by directory write, not credential re-issuance.** This makes attribute-mutation observability (§4.2) the central audit-trail concern.
- **Delta 3 — Multi-hop is not the native shape.** Identity-bound deployments do not natively express principal → agent → sub-agent chains; the bridge contract of §6 supplies the multi-hop-shaped synthetic mandate envelope.
- **Delta 4 — The platform is the authority surface; the platform's API is the bridge.** The bridge contract of §6 specifies the semantic content the platform-API-derived synthetic mandate Must convey, leaving the platform-side wire-level shape to the platform.

3.1.1 Single-Credential PoA-Extension (S3) — Why the Bridge Is Still Required (Normative)

The four deltas of §3.1 are governance-model properties, not credential-format properties. Adding fields to a single credential body does not resolve any of them. The six structural disadvantages of S3:

- **3.1.1.1 Authority-mutation drift — Delta 2 unresolved.** SC7 cache-poisoning re-emerges. S3's merged credential is signed at issuance and carries PoA-shape claims as static body fields; after issuance the principal's authority continues to live in the directory and continues to mutate by directory write. The credential's PoA claims drift silently from the directory's authoritative state.
- **3.1.1.2 Missing discrete principal-delegation event — NCO unaddressed.** S3 deployments are NCO by default and cannot be reclassified upward without separating the principal-delegation event from credential issuance — at which point the deployment has effectively reached for the §6 bridge structure and become S2.
- **3.1.1.3 Multi-hop chain semantics absent — Delta 3 unresolved.** Each S3 credential is independently signed with no chain-binding cryptographic material; the narrowing invariant of RFC 0115 §3.7 cannot be cryptographically enforced across S3 credentials.

- **3.1.1.4 Lifecycle entanglement — revocation coupling.** S3 collapses credential lifecycle and authority lifecycle into a single artefact; cannot independently revoke authority while preserving identity.
- **3.1.1.5 Cross-family interoperability break — vendor-specific wire format.** A CCPE-A downstream cannot validate an S3 merged credential without a vendor-specific parser.
- **3.1.1.6 Governance-model versus credential-format — the category error.** Adding PoA-shape attributes to a single credential body does not change the governance model; it only encodes a snapshot of it at issuance time.

Explicit non-conformance statement. S3 is non-conformant to Standard / Strict / Platform-Native and Must not be declared at any of those profiles.

3.2 The Identity-Bound Three-Service Split

Service | Responsibility | Typical platform-side realisation:

Directory | Source of truth for the agent's identity object and its attributes. | Microsoft Entra ID directory; Okta Universal Directory; Auth0 user/application store; PingOne directory; SPIFFE/SPIRE registration store.

Authority-Surface | Administrative API and policy-engine layer that manipulates the Directory. Natural emission point for mandate-mutation audit events. | Microsoft Graph; Okta Management API; Auth0 Management API; PingOne Management API; SPIRE Server registration API.

Runtime-PEP | Runtime enforcement component. Reads from the Directory and evaluates per the 16-check pipeline of §5.2. Optionally consumes a synthetic mandate envelope from the bridge contract (§6). | Microsoft Entra Conditional Access + downstream resource-server validation; Okta authorization servers + Universal Logout; Auth0 Actions + FGA; PingOne authorization policies; SPIRE Agent + workload-API attestation.

A CCPE-G-conformant deployment Must have a clearly-identified Directory, Authority-Surface, and Runtime-PEP, with the boundary primitives observable at the Authority-Surface → Directory and Runtime-PEP → Directory boundaries.

3.3 The Four Boundary Primitives

1. **Identity-Issuance.** Creation of an agent's identity object in the Directory. Failure to record the principal-to-agent delegation at issuance is classified as NCO.
2. **Identity-Attribute-Mutation.** Write of one or more attributes on an existing identity object. Failure to emit a mandate-mutation event of sufficient detail at this boundary is classified as NCP.
3. **Identity-Revocation.** Disablement, deletion, or expiry of an agent's identity object.
4. **Identity-Introspection.** Read of the identity object's current attribute state by the Runtime-PEP at the moment of action. The action's audit event Must reference the introspection.

3.4 Non-Conformant Variants (NCI / NCP / NCO / NCM) — Catalogue-and-Prescribe

The per-family non-conformance dimension is mandate-mutation-tracking presence at the identity-mutation boundary. Each variant names a specific Phase-1 layer that a Phase-2-only deployment does not supply.

3.4.1 CCPE-G-NCI — Non-Conformant Issuance

Audit-trail value: ``ccpe-g-nci``. Identity issued without recording the principal-to-agent delegation event. The synthetic mandate envelope's ``principal`` field Must be marked ``unverified``; ``principal_evidence`` records the administrator-assertion.

3.4.2 CCPE-G-NCP — Non-Conformant Persistence

Audit-trail value: ``ccpe-g-ncp``. Identity-attribute mutations occur without emitting an authority-mutation audit event of sufficient detail. The synthetic mandate envelope's ``mutation_history`` field Must be marked ``unavailable``; ``current_state_evidence`` records the directory snapshot used.

3.4.3 CCPE-G-NCO — Non-Conformant Origination

Audit-trail value: ``ccpe-g-nco``. Identity issued by an administrator-side process rather than originating in a principal's exercise of delegation authority. The synthetic mandate envelope's ``principal_consent`` field Must be marked ``administrator-asserted``; ``consent_evidence`` records the issuance-side actor.

NCO is by far the most common in current production identity-bound deployments; it becomes a security-relevant non-conformance only when the action class requires principal-direct-consent evidence (GDPR Art. 22 automated decision-making, PSD2 SCA, fiduciary-action classes of CCPE-F).

3.4.4 CCPE-G-NCM — Non-Conformant Multi-Principal

Audit-trail value: ``ccpe-g-ncm``. A single identity object used to act on behalf of multiple principals concurrently without per-principal mandate disambiguation at action time. The synthetic mandate envelope's ``principal`` field Must be marked ``multi``; ``principal_resolution_hint`` records whatever per-action context the deployment Can offer.

3.4.4.1 NCM Per-Action Disambiguation Requirements (Normative)

Above the Minimal profile, the `principal_resolution_hint` field Must Not be empty. It Must carry at minimum: (a) `session_id` or equivalent transactional correlator; (b) `request_context_id` propagated from the upstream caller; (c) `principal_claim_source` (one of `session-cookie` / `oauth-claim` / `header-asserted` / `mtls-cert-binding`); (d) `originating_network_zone` per §5.2 row 14. Strict deployments Must additionally bind the resolved principal to the credential via DPoP, mTLS, or equivalent (per S5 in §12).

3.4.5 Combinations and Mixed Deployments

A deployment Can be non-conformant on more than one dimension simultaneously. The audit-trail value Should be set to the most-restrictive applicable variant; the full set is recorded in a separate ``ccpe_g_variants`` field.

3.5 Profile-Determination Q-Table (Normative)

Q	Question	If Yes — Profile floor
---	---	---
Q1	Internal, low-risk, non-commerce, single-hop on first-party resources?	Minimal
Q2	Sub-agent (multi-hop) actions per §6.2 (a)?	Standard (S2 required)
Q3	Cross-platform actions per §6.2 (b)?	Standard (S2 required)

| Q4 | Commerce-class actions per §6.2 (c)? | Standard
(recommended) / Strict (required) |

| Q5 | Consumer-requested envelopes per §6.2 (d)? | Standard
(S2 required) |

| Q6 | Revocation within 60 s with push semantics? | Strict |

| Q7 | Drift reconciliation as normative requirement? | Strict
|

| Q8 | Foundation-recognised platform binding (Appendix
A/B/C/D/E)? | Platform-Native |

| Q9 | Asserts NCI/NCP/NCO/NCM variant codes? | (orthogonal –
declarative) |

Cross-validation against §11.1a. A Q-table determination of Standard or higher combined with a §3.0a scenario of S1 or S3 is rejected by the Conformance Statement reviewer.

3.6 Per-Vendor Cookbook Template (Normative)

Each cookbook includes five sub-sections in order: (1) Scope and posture; (2) Three-service mapping; (3) Boundary-primitive mapping; (4) Bridge-contract mapping. Optional (5) is reserved for vendor-acknowledgment-update where applicable.

All architectural mappings in any cookbook authored against this template are derived from publicly available vendor documentation, public conference disclosures, and public source code as of the cookbook's publication date. Nothing constitutes vendor evaluation, endorsement, partnership claim, or capability warranty.

4. The Identity-as-Authority Object Model

4.1 Identity-Issuance — `identity\_issuance` Event

Required fields: `event\_id`, `event\_time` (RFC 3339), `identity\_id`, `identity\_type`, `principal` (set to `unverified` for NCI; `administrator-asserted` for NCO), `principal\_evidence`, `initial\_attributes`, `actor`, `phase2\_evaluation.profile`.

4.2 Identity-Attribute-Mutation — `identity\_attribute\_mutation` Event

Required fields: `event\_id`, `event\_time`, `identity\_id`, `mutations` (array of `{attribute\_name, prior\_value, new\_value, prior\_etag, new\_etag}`), `actor`,

``actor_intent``, ``phase2_evaluation.profile``. Deployments that cannot emit per-attribute decomposition (NCP) Should emit a single ``directory.write`` event with variant code ``ccpe-g-ncp`` and ``mutations`` marked ``unavailable``.

4.3 Identity-Revocation — ``identity_revocation`` Event

Required fields: ``event_id``, ``event_time``, ``identity_id``, ``revocation_kind`` (one of ``disabled`` / ``deleted`` / ``expired`` / ``suspended``), ``reason``, ``actor``, ``propagation_status``, ``phase2_evaluation.profile``. Identity-revocation events Are the CCPE-G analogue of mandate revocation. Propagation discipline per §7.1.

4.4 Identity-Introspection — ``identity_introspection`` Boundary

The action's audit event Must include: ``directory_etag``, ``directory_freshness``, ``attributes_consulted``. Deployments that cannot record ``directory_etag`` Must emit a ``directory_etag_unavailable`` flag.

5. Pre-Action Enforcement Surface

5.1 The Identity-PEP

The Identity-PEP runs the 16-check pipeline of RFC 0117 against the agent's identity-attribute-encoded authority and produces a PERMIT / DENY / CONSTRAIN decision per RFC 0117 §4. Per §3.0, the Identity-PEP Is the Phase-1 component layered above the IAM platform's native Phase-2 authentication enforcement. For any action above the Minimal profile of §8.1, the Identity-PEP Must derive (or consume a pre-derived) synthetic mandate envelope per §6 and evaluate it against the requested action; pure Phase-2 evaluation without a synthetic mandate Is insufficient for CCPE-G conformance above Minimal. Check 16 of the pipeline (§5.2) Is the conformance gate that enforces this requirement.

5.2 The Sixteen-Check Pipeline in Identity-Bound Form

#	Check	Source-of-truth in identity-bound deployment
1	Credential signature validity	Platform's credential validator (Entra token validator; Okta authorization server; SPIRE SVID validator).
2	Credential freshness (<code>`nbf`</code> / <code>`exp`</code>)	Credential body.

- | 3 | Credential audience (`aud`) | Credential body. |
- | 4 | Subject identity | Credential body (`sub`) cross-referenced with Directory `identity\_id`. |
- | 5 | Principal identity | Directory's principal-relationship attribute (`actsOnBehalfOf` or equivalent). |
- | 6 | Allowed action set | Directory's entitlement / group-membership attributes. |
- | 7 | Resource scope | Directory's resource-scope attributes. |
- | 8 | Operating-window TTL | Credential `exp` $\cap$ Directory's lifecycle-policy attributes. |
- | 9 | Multi-hop scope-narrowing invariant | ****Bridge contract (§6)**** – identity-bound deployments do not natively enforce this. |
- | 10 | Revocation-status freshness | Directory introspection per §4.4; cache-TTL respects §7.1. |
- | 11 | Principal-consent validity | Directory's principal-consent attribute or audit-event reference; for NCO, administrator-asserted. |
- | 12 | Resource-side access-control intersection | Resource-server-side access control evaluated independently. |
- | 13 | Concurrency / rate-limit envelope | Directory's rate-limit attribute or platform-side throttle. |
- | 14 | Geographic / network-zone constraint | Directory's Conditional Access attributes or network-zone policy. |
- | 15 | Audit-emission reachability | Identity-PEP-side reachability check; fail-closed-on-doubt – Must DENY if cannot emit. |
- | 16 | ****Bridge-contract conformance (CCPE-G-specific)**** | Identity-PEP determines whether the action requires bridge handoff per §6.2 trigger conditions and includes the synthetic mandate envelope in the downstream call. |

Check 16 is the only CCPE-G-specific addition to the RFC 0117 16-check vocabulary.

5.3 PERMIT / DENY / CONSTRAIN in Identity-Bound Form

The CONSTRAIN decision is particularly relevant: the Directory's attribute set typically encodes a “maximum” scope. The Identity-PEP Should issue CONSTRAIN when the agent's current request is wider than the identity's current attribute-encoded maximum, downgrading rather than denying outright.

5.4 Latency, Caching, and Failure-Mode Discipline (Normative)

- **Series-evaluation cost.** Phase 2 → Phase 1 in series adds a per-action latency budget; deployments Should target ≤ 50 ms incremental at the bridge boundary for cached-introspection paths.
- **Caching guidance.** Identity-introspection results Should be cached against `directory_etag`; cache TTL Must Not exceed the §7.1 revocation window for the declared profile (24h Minimal / 1h Standard / 60s Strict).
- **Failure-mode discipline** (fail-closed default). When the bridge service is unreachable, the Identity-PEP Must DENY for any action triggered by §6.2 (a)–(c) above the Minimal profile. Fail-open is prohibited above Minimal. Bridge unavailability Must be recorded as a `bridge_emission` event with

```
trigger_condition = "fail-closed-bridge-unavailable"
```

and

```
billable = false.
```

6. Bridge Contract — CCPE-G → CCPE-A / CCPE-B / CCPE-F (the Phase-1 Restoration Mechanism)

The bridge contract is the **central operational mechanism** by which a Phase-2-only identity-bound deployment becomes Phase-1 + Phase-2 PoA-conformant per §3.0. The bridge is not optional above the Minimal profile. Per §3.0 and §11.1 (rows viii–ix and xv), bridge emission is Required at Standard and Strict for the action classes named in §6.2 (a) and (b), Required at Strict for (c), and supported across all profiles for (d). A deployment that elides the bridge for §6.2 (a)–(c) actions Must downgrade its declared profile to Minimal.

6.1 The Synthetic Mandate Envelope

The synthetic mandate envelope conforms to the GAAuth PoA Credential structure of RFC 0115. Required fields:

Field	Derivation in CCPE-G
---	---

| ``mandateId`` | Bridge-assigned UUID (new at v0.7 – required by SDK §13.A reference implementation). |

| ``issuedAt`` | RFC 3339 timestamp (new at v0.7). |

| ``issuer`` | Foundation-side bridge service identifier or platform-managed bridge identifier (new at v0.7). |

| ``proof`` | Detached signature or hash chain referencing ``bridge_evidence`` (new at v0.7). |

| ``principal`` | Directory's principal-relationship attribute. NCI: ``unverified``; NCO: ``administrator-asserted``; NCM: ``multi`` with ``principal_resolution_hint``. |

| ``subject`` | Directory's ``identity_id`` for the agent. |

| ``scope`` | Derived from directory's entitlement / group-membership / Conditional-Access-scope attributes per the platform-specific mapping. |

| ``allowed_actions`` | Derived from directory's entitlement attributes per the platform-specific mapping. |

| ``expiry`` | The lesser of: credential ``exp``, identity object's lifecycle-policy expiry, bridge-contract operating-window TTL. |

| ``revocation_handle`` | Reference back to the identity object (``identity_id`` plus ``directory_etag`` of the snapshot used). |

| ``delegation_chain`` | If the action involves a sub-agent, a chain of synthetic mandates with mandatory scope narrowing per RFC 0115 §3.7, ****enforced at the bridge boundary even when the platform's directory schema does not natively enforce it****. |

| ``bridge_evidence`` | Structured record: ``identity_id``, ``directory_etag``, ``identity_issuance`` event reference, audit-history range searched, CCPE-G variant code. |

| ``phase2_evaluation.profile`` | ``ccpe-g`` or one of the variant codes. |

6.1.1 Wire-Level Example (Informative)

The following non-normative example shows one synthetic-mandate envelope derived from a Microsoft Entra Agent ID identity object (per Appendix A) plus the paired ``bridge_emission`` audit event of §6.4. The deployment is Standard-profile, S2 (§6 bridge), NCO variant (``ccpe-g-nco``) — the most common production starting state per §3.4.3. Field semantics are normative per §6.1 and §6.4; concrete values are illustrative.

Synthetic mandate envelope (`application/vnd.gimel.gauth.poa+jwt` payload, decoded):

```
```json
{
 "mandateId": "7c3f2a18-4e9b-4d21-9c8e-1f5a6b7c8d90",
 "issuedAt": "2026-05-04T14:22:07Z",
 "issuer": "urn:gimel:bridge:entra-agent-id-tenant-a1b2c3d4",
 "proof": {
 "alg": "EdDSA",
 "kid": "gimel-bridge-signing-2026-05",
 "sig": "k3J9...detached-signature-base64url...A2x7"
 },
 "principal": "administrator-asserted",
 "principal_evidence": {
 "actor": "alice.admin@contoso.onmicrosoft.com",
 "actor_object_id": "5f8e2c91-3a7b-4d12-8e6f-9c1a2b3d4e5f",
 "issuance_event_ref": "graph-audit:7e1d4c92-..."
 },
 "subject": "agent-9f8e7d6c-5b4a-3210-fedc-ba9876543210",
 "scope": [
 "Mail.Read",
 "Calendars.ReadWrite",
 "Sites.Read.All:contoso.sharepoint.com/sites/finance"
],
 "allowed_actions": [
 "read:mailbox",
 "read:calendar",
 "write:calendar-event",
 "read:sharepoint-document"
],
}
```

```
"expiry": "2026-05-04T15:22:07Z",

"revocation_handle": {

 "identity_id": "agent-9f8e7d6c-5b4a-3210-fedc-
ba9876543210",

 "directory_etag": "W/\\"JzEsMjQ4OTcxNTI3MzAwMDAwMDAwMCC=\\""

},

"delegation_chain": null,

"bridge_evidence": {

 "identity_id": "agent-9f8e7d6c-5b4a-3210-fedc-
ba9876543210",

 "directory_etag":
"W/\\"JzEsMjQ4OTcxNTI3MzAwMDAwMDAwMCC=\\"",

 "identity_issuance_event_ref": "graph-audit:7e1d4c92-2f8b-
4a31-9d6e-0c1b2a3d4e5f",

 "audit_history_range": {

 "from": "2026-04-15T09:00:00Z",

 "to": "2026-05-04T14:22:07Z"

 },

 "ccpe_g_variant": "ccpe-g-nco"

},

"phase2_evaluation": {

 "profile": "ccpe-g-nco",

 "ccpe_g_variants": ["ccpe-g-nco"]

}

}

...
```

**Paired `bridge\_emission` audit event** (per §6.4, written into the unified GAuth audit JSON stream and into Microsoft Purview before the envelope is delivered downstream — the persistence-before-stream invariant of RFC 0140 §9.4):

```
```json
{
```

```
"event_id": "b1c2d3e4-5f60-7a8b-9c0d-1e2f3a4b5c6d",
"event_time": "2026-05-04T14:22:07.184Z",
"event_type": "bridge_emission",
"synthetic_mandate_hash":
"sha256:9a8b7c6d5e4f3a2b1c0d9e8f7a6b5c4d3e2f1a0b9c8d7e6f5a4b3c
2d1e0f9a8b",
"identity_id": "agent-9f8e7d6c-5b4a-3210-fedc-ba9876543210",
"directory_etag": "W/\\"JzEsMjQ4OTcxNTI3MzAwMDAwMDAwMCC=\\"",
"identity_issuance_event_ref": "graph-audit:7e1d4c92-2f8b-
4a31-9d6e-0c1b2a3d4e5f",
"downstream_consumer": "ccpe-a:agent-runtime-prod-eu-west-
1",
"trigger_condition": "cross-platform",
"phase2_evaluation": {
  "profile": "ccpe-g-nco"
},
"actor": "urn:gimel:bridge:entra-agent-id-tenant-a1b2c3d4",
"subject": "agent-9f8e7d6c-5b4a-3210-fedc-ba9876543210",
"details": {
  "platformId": "entra-agent-id-tenant-a1b2c3d4",
  "operatorMode": "gimel_managed",
  "tariffTier": "S",
  "billable": true,
  "signing_custody": "foundation-managed"
}
}
...
```

Verification flow at the downstream consumer. The downstream (here a CCPE-A agent runtime) Must (i) compute SHA-256 over the canonicalised envelope and verify equality with `synthetic\_mandate\_hash` on the paired `bridge\_emission` event; (ii) verify `bridge\_evidence.directory\_etag` against an independent action-time

introspection of the Microsoft Graph agent object per §6.6.3 (ii); (iii) verify the ``proof.sig`` against the bridge service's published JWKS for ``proof.kid``; (iv) reject the envelope if any of (i)–(iii) fails, per Security Consideration SC10.

The envelope's ``phase2_evaluation.profile = "ccpe-g-nco"`` signals to the CCPE-A consumer that principal-consent is administrator-asserted, not principal-direct; the consumer's per-action-class policy decides whether NCO-grade evidence is acceptable for the requested action.

6.2 The Bridge Boundary

The bridge boundary Must be triggered when any of the following conditions hold:

- a) **Sub-agent action** (identity-to-identity delegation chain). The synthetic mandate's ``delegation_chain`` field Must be populated; multi-hop scope-narrowing per RFC 0115 §3.7 Must be enforced at the boundary.
- b) **Cross-platform action** (Entra-issued identity calls a resource validated by Okta authorization server; Auth0-issued identity calls a SPIRE-attested workload).
- c) **Commerce-class action** targeting a CCPE-F-conformant downstream resource (per the ``com.gimel.gauth.commerce_mandate`` UCP capability of RFC 0170). The synthetic mandate Must carry the `commerce-mandate-shape` fields per RFC 0170 §A.
- d) **Consumer-requested** synthetic mandate envelope via ``Accept: application/vnd.gimel.gauth.poa+jwt`` or equivalent.

When none of (a)–(d) hold, the bridge boundary is not triggered and the action proceeds in pure identity-bound form.

6.3 Round-Trip Identity → Mandate

A CCPE-G deployment Should support round-trip translation: Identity → Mandate per §6.1; Mandate → Identity (the reverse bridge) requires registering the PoA Credential's ``subject`` against an identity object and propagating subsequent identity-attribute mutations back to the PoA Credential's `scope / allowed_actions` fields. The reverse-bridge direction Is non-trivial in current production deployments and Is flagged in §20 as an open issue for a future version.

6.4 Bridge Audit-Trail Discipline

Every emission of a synthetic mandate envelope Must be paired with a ``bridge_emission`` audit event recording: ``event_id``, ``event_time``, ``synthetic_mandate_hash``, ``identity_id``, ``directory_etag``,

`identity\_issuance\_event\_ref`, `downstream\_consumer`, `trigger\_condition` (one of `sub-agent-action` / `cross-platform` / `commerce-class` / `consumer-requested`), `phase2\_evaluation.profile`. The hash discipline allows independent verification by an audit-correlation service.

6.5 Bridge Emission Metering and Open-Core Symmetry Rules (Normative)

This subsection states the metering and billability rules that an open-core Foundation operator (e.g., Gimel Auth) Must honour when running the bridge service of §6 on behalf of deployments. The rules realise the cost-causer-pays principle while preserving the open-core symmetry guarantee that a Foundation operator incurs **zero variable cost** on Tariff-O deployments.

6.5.1 Per-call metering

Every bridge emission per §6.4 Must produce a single `BridgeEmissionMeteringRecord` with at minimum: `mandateId`, `platformId` (the registered `identity\_platform` instance per §13.A), `tariffTier` (one of `O` / `S` / `M` / `L`), `operatorMode` (one of `null\_or\_user` / `user\_provided\_required` / `user\_self\_hosted` / `gimel\_managed` / `gimel\_or\_user`), `triggerCondition` (per §6.2), `billable` (boolean), `emittedAt`. Billing aggregation Is downstream of metering and is not specified here.

6.5.2 Open-core symmetry guarantees

The following invariants Must hold and Should be enforced at the metering call site:

- i. `user\_self\_hosted` Is never billable. `operatorMode = "user\_self\_hosted"` Must always produce `billable = false`. The user is hosting the bridge themselves; the Foundation operator records the emission only for ecosystem telemetry.
- ii. Tariff-O coerces to `billable = false`. When `tariffTier = "O"`, the metering layer Must set `billable = false` regardless of `operatorMode`. If a `gimel\_managed` emission is observed at Tariff O, the metering layer Should additionally emit a reconciliation warning log naming the registration that admitted the inconsistency; the emission itself Is recorded with `billable = false`.
- iii. Unknown `platformId` fails closed. A `recordBridgeEmission()` invocation referencing a `platformId` not present in the `identity\_platform` registry Must throw (fail-closed). Silent non-billable recording on unknown platforms Is prohibited because it weakens the cost-causer-pays property.

6.5.3 Tariff matrix gates ***who provisions***, not “what checks run”

The tariff matrix of §13.A gates “who is permitted to provision the connector” at each tier. It Must Not gate which §5.2 pipeline checks execute, which §3.4 variants are available, or which §8 conformance profiles are achievable. A Tariff-O deployment running its own bridge Must be able to declare any §8 profile (subject to §11.1 feature-matrix evaluation). The tariff and the conformance profile are orthogonal axes.

6.5.4 Cost-causer-pays principle

Variable cost incurred by the Foundation operator at the bridge boundary (CPU, downstream-API rate-budget consumption, audit-storage growth) Should be attributable to the registered operator who chose `gimel\_managed` at Tariff S/M/L. Open-core (Tariff O) operators Must not subsidise paid tiers; paid-tier operators Must not be billed for emissions they did not cause.

6.6 Bridge Service Trust Model (Normative)

6.6.1 Signing authority.

The synthetic mandate envelope's proof field Must be a detached signature produced by a key under one of three custody models: (a) Foundation-managed (Foundation-side bridge service holds the signing key in HSM); (b) user-self-hosted (deployer holds the key); (c) platform-managed (IAM-platform-side key per cookbook binding). The custody model Must be declared in the §11.2 Conformance Statement and recorded on every bridge_emission event as signing_custody.

6.6.2 Key rotation.

Signing keys Must rotate at least every 90 days for Standard/Strict; the prior key's public half Must remain verifiable for one full revocation window after rotation per §7.1.

6.6.3 Bridge-as-target threat surface.

A compromised bridge can forge principal-consent claims and synthesise mandates not derived from any directory state. Defences: (i) every emission Must be paired with an immutable bridge_emission audit event before downstream delivery; (ii) downstream consumers Must verify bridge_evidence.directory_etag against an independent introspection at action-time; (iii) bridge-key compromise Must trigger emergency revocation of all envelopes signed under the compromised key within the §7.1 Strict window (60 s + push).

6.6.4 Bridge-emission containment.

A bridge that observes a recordBridgeEmission() rejection rate above a configurable threshold Must self-quarantine and escalate per §18 Correction Channel.

7. Revocation and Lifecycle

7.1 Revocation Propagation

Profile (per §8)	Maximum revocation-tolerance window
Minimal	24 hours
Standard	1 hour
Strict	60 seconds (push-revocation Required)
Platform-Native	Per platform's published guarantee

Deployments that cannot meet the window for the chosen profile Must downgrade to the next-most-permissive profile.

7.2 Attribute-Mutation Propagation

Same windowing discipline as revocation. Operationally distinct because mutation may be scope-narrowing (must be respected promptly) or scope-broadening (less time-critical from a security standpoint).

7.3 Drift Reconciliation

The Runtime-PEP Must implement a drift-detection mechanism (typically periodic `etag` introspection) and Must reconcile detected drift by re-introspecting the full attribute set. Drift-reconciliation events Should be emitted as `identity\_introspection` events with a `drift\_detected` flag.

7.4 Introspection Freshness Bounds (Normative)

Profile	Maximum directory_etagstaleness
Minimal	24 h
Standard	1 h

Profile	Maximum directory_etagstaleness
Strict	60 s
Platform-Native	Per platform binding

An introspection older than the bound Must be re-run before the Identity-PEP issues PERMIT or CONSTRAIN. Drift detected during freshness-bound enforcement Must be emitted as an identity_introspection event with drift_detected = true per §7.3.

8. Governance Profile Categories

Profile	Suitability	Variants permitted	Revocation window	Bridge emission
--- ---	---	---	---	---
8.1 Minimal Low-risk, internal, non-fiduciary action classes. NCI / NCP / NCO / NCM 24 h Optional (consumer-requested only)				
8.2 Standard Typical enterprise deployments. NCO / NCM (Should not operate at NCI / NCP) 1 h Required for sub-agent and cross-platform				
8.3 Strict Safety-critical, fiduciary, regulated. None – conformant CCPE-G only 60 s with push-revocation Required Required for all §6.2 triggers				
8.4 Platform-Native Bound to a specific platform's published guarantees (Appendix A; Appendices B-E Preliminary). Per platform binding Per platform Per platform binding				

9. Module / Practice Taxonomy

Slot	Module / practice
---	---
M1	Directory schema for agent identity (attribute-encoded authority)
M2	Authority-Surface API + admin workflow + principal-side consent capture
M3	Audit-event emission at the four boundary primitives

| M4 | Runtime-PEP integration with the 16-check pipeline |
| M5 | Bridge-contract implementation (synthetic-mandate
emission per §6) |
M6	Revocation propagation per §7.1
M7	Attribute-mutation propagation per §7.2
M8	Drift reconciliation per §7.3
M9	Cross-platform interoperoperation evidence (when
applicable)	
M10	Per-profile threshold compliance (revocation window,
audit cadence) |

10. Governance Event Schema

All events conform to the unified GAuth audit JSON shape established by RFC 0140 v1.2.1 §9, with the four boundary-primitive event types and the `bridge\_emission` event type:

```
```json
{
 "event_id": "<uuid>",
 "event_time": "<rfc3339>",
 "event_type": "identity_issuance |
identity_attribute_mutation | identity_revocation |
identity_introspection | bridge_emission | action",
 "phase2_evaluation": {
 "profile": "ccpe-g | ccpe-g-nci | ccpe-g-ncp | ccpe-g-nco
| ccpe-g-ncm",
 "ccpe_g_variants": ["<set when non-conformant on more than
one dimension>"]
 },
 "actor": "<actor identifier>",
 "subject": "<identity_id>",
 "details": { /* event-type-specific fields per §4 and §6.4
*/ }
}
```

` ` `

The `persistence-before-stream` invariant of RFC 0140 §9.4 applies: events Must be written to durable storage before being streamed.

## 11. Conformance

### 11.1 Conformance Feature Matrix

#	Feature	Minimal	Standard	Strict	Platform-Native
(i)	Directory schema for agent identity (M1)	Required	Required	Required	Required
(ii)	Principal-relationship attribute on identity object	Recommended	Required	Required	Per platform binding
(iii)	Audit emission at `identity_issuance` (M3)	Required	Required	Required	Required
(iv)	Audit emission at `identity_attribute_mutation` with per-attribute decomposition (M3)	Recommended	Required	Required	Per platform binding
(v)	Audit emission at `identity_revocation` (M3)	Required	Required	Required	Required
(vi)	Audit emission at `identity_introspection` with `directory_etag` (M3)	Optional	Required	Required	Per platform binding
(vii)	16-check pipeline integration (M4)	Required	Required	Required	Required
(viii)	Bridge-contract emission for sub-agent and cross-platform actions (M5)	Optional	Required	Required	Per platform binding
(ix)	Bridge-contract emission for commerce-class actions per RFC 0170 (M5)	Optional	Recommended	Required	Per platform binding
(x)	Revocation propagation within profile window (M6, §7.1)	24 h	1 h	60 s + push	Per platform
(xi)	Attribute-mutation propagation within profile window (M7, §7.2)	24 h	1 h	60 s + push	Per platform

(xii)	Drift reconciliation (M8)	Recommended	Required	Required	Per platform binding
(xiii)	`persistence-before-stream` honoured (RFC 0140 §9.4)	Recommended	Required	Required	Per platform binding
(xiv)	Multi-hop scope-narrowing enforced at bridge boundary per RFC 0115 §3.7	N/A	Required when applicable	Required	Per platform binding
(xv)	Permitted non-conformant variants	NCI / NCP / NCO / NCM	NCI / NCP / NCO / NCM	None	Per platform binding

### 11.1a Conformance by Deployment Scenario (S1 / S2 / S3)

Scenario	Minimal	Standard	Strict	Platform-Native	Reason for non-conformance
---	---	---	---	---	---
**S1**	Pure Phase-2-only	Conformant (with NCI/NCP/NCO/NCM allowances per row xv)	Non-conformant	Non-conformant	Non-conformant   No bridge emission; no audit-event schema at boundary primitives at Foundation-defined detail; default NCI + NCP + NCO + NCM.
**S2**	§6 Bridge (two-artefact)	Conformant	Conformant (bridge required for §6.2 (a)/(b); recommended for (c))	Conformant (bridge required for all §6.2 triggers; revocation 60 s + push)	Conformant per published platform binding
**S3**	All-in-one merged credential	Conformant (with same allowances)	Non-conformant	Non-conformant	Non-conformant   All six structural disadvantages of §3.1.1 apply. Reaching the §3.0a.3 five-condition bar reclassifies as S2-by-another-name.

A deployment Must declare both scenario (S1/S2/S3) and profile (Minimal/Standard/Strict/Platform-Native) in its Conformance Statement per §11.2. The Conformance Statement reviewer Must reject any combination shown non-conformant above.

## 11.2 Conformance Letter Sequence

Letters (i)–(xv) are reserved per the parallel-naming convention. Cross-RFC consumers Should reference CCPE-G features by both letter and section. A deployment Must publish a Conformance Statement naming the chosen profile, the per-feature disposition (Required / Recommended / Optional / N/A), the applicable CCPE-G variant code, and **“(new at v0.7)”** the per-`identity_platform`` instance disposition where the deployment uses the §13.A multi-instance registry across multiple cookbooks.

## 11.3 Conformance Test Vectors (Informative — Queued)

A reference test-vector corpus is queued for publication at <https://github.com/Gimel-Foundation/rfc-0210-test-vectors>, structured per profile (Minimal / Standard / Strict / Platform-Native), per cookbook (Appendices A–E), and per non-conformant variant (NCI / NCP / NCO / NCM). Each vector pairs an input directory state with the expected synthetic mandate envelope, the expected bridge\_emission audit event, and the expected Identity-PEP decision per §5.2. Vendor self-attestation Should reference the corpus version under which conformance was validated.

## 12. Security Considerations

CCPE-G inherits the security considerations of RFCs 0110 / 0111 / 0115 / 0117, with the following CCPE-G-specific additions:

- **SC1 — Directory-as-single-point-of-failure.** Defence-in-depth at the Directory layer (privileged-access management, change-detection alerting, immutable audit logs) Is a CCPE-G prerequisite, not optional.
- **SC2 — Attribute-mutation race condition.** The revocation-tolerance window of §7.1 bounds the race; deployments Should set the window per the action class's tolerance for stale authority.
- **SC3 — Synthetic-mandate forgery.** A downstream consumer Must verify the `bridge_emission`` audit event's hash against the received envelope. A synthetic mandate received outside a verifiable bridge-emission Must be rejected.
- **SC4 — NCO + privileged-administrator collusion.** Defence: require principal-side counter-signature for issuance of identities authorised for action classes above a configured sensitivity threshold.
- **SC5 — NCM session-context spoofing.** Defence: bind the session-side principal claim to the credential via DPoP, mTLS, or equivalent.
- **SC6 — Bridge-boundary downgrade.** Downstream consumers Must respect variant codes and apply per-action-class policy that names which variants are acceptable.

- **SC7 — Identity-introspection cache poisoning.** Cache entries Must be signed by the Authority-Surface and verified by the Runtime-PEP; cache-TTL Must be enforced even when the cache appears fresh.

- **SC8 — Tariff-misregistration revenue leakage.** A ``gimeL_managed`` operator-mode registered against an ``identity_platform`` instance whose tariff tier is ``O`` Must be detected and coerced to ``billable = false`` per §6.5.2 (ii). Failure to detect would either subsidise a paid customer at open-core cost or — worse — bill an open-core user. Defence: the §13.A registry Must enforce the tariff-mode matrix at registration time and Must additionally enforce it at every ``recordBridgeEmission()`` call site.

- **SC9 — Unknown-``platformId`` silent recording.** A ``recordBridgeEmission()`` call referencing an unregistered ``platformId`` Must fail closed (throw); silent non-billable recording Is prohibited because it permits unauthenticated bridges to operate undetected.

- **SC10 — Bridge-as-target.** A compromised bridge service can forge synthetic mandates without any directory provenance. Defences per §6.6.3: paired `bridge_emission` audit event Required before downstream delivery; downstream verification of `bridge_evidence.directory_etag` against independent action-time introspection; emergency key rotation within the §7.1 Strict window on suspected compromise.

## 13. Implementation Guidance

This section provides non-normative implementation guidance organised into seven archetypes (workforce-IAM; open-source IAM; workload/machine identity; CI/workload-OIDC; cloud-provider IAM; IGA non-human / agent-identity governance; enterprise-application-suite IAM) plus an eighth grouping of agentic-identity-native developer-auth platforms.

### 13.1 Enterprise Workforce-IAM

Microsoft Entra ID + Entra Agent ID (Appendix A, Preliminary); Okta + Okta for AI Agents + Auth0 + Token Vault (Appendix B, Preliminary); Ping Identity / PingOne / DaVinci / ForgeRock (Appendix C, Preliminary); IBM Security Verify (Appendix F, future); Oracle IDCS / OAM (Appendix G, future); OneLogin / One Identity (Appendix H, future); JumpCloud (Appendix I, future); Curity Identity Server (Appendix AA, future); Microsoft AD + AD FS (Appendix AB, future).



## 13.2 Open-Source Enterprise IAM

Keycloak / Red Hat build of Keycloak (Appendix J, future); WSO2 Identity Server (Appendix K, future); Authentik (Appendix AC, future); Zitadel (Appendix AD, future); Ory Kratos / Hydra / Keto (Appendix AE, future); FreeIPA / Red Hat IdM (Appendix AF, future). The Foundation Will publish a reference Keycloak Authorization Services policy bundle implementing the bridge contract of §6 as an SPI extension under MPL 2.0 + Foundation Additional Terms.

## 13.3 Workload-Identity / Machine-Identity

SPIFFE / SPIRE (Appendix D, Preliminary); HashiCorp Vault + Boundary (Appendix L, future); Teleport (Appendix M, future); Aembit (Appendix N, future); Akeyless (Appendix O, future); CyberArk + Conjur + Venafi (Appendix E, Preliminary).

## 13.4 CI / Workload OIDC as Agent-Identity Source

GitHub Apps + GitHub Actions OIDC (Appendix AG, future); GitLab OIDC (Appendix AH, future); CircleCI OIDC (Appendix AI, future); Spacelift OIDC (Appendix AJ, future).

## 13.5 Cloud-Provider IAM with Agent-Identity Surfaces

AWS IAM Identity Center + IAM Roles Anywhere + Bedrock AgentCore Identity (Appendix P, future); Google Cloud IAM + Workload Identity Federation + Agentspace (Appendix Q, future).

## 13.6 IGA — Non-Human / Agent-Identity Governance

SailPoint Identity Security Cloud (Appendix R, future); Saviynt Identity Cloud (Appendix S, future); Britive (Appendix T, future); Strata Identity (Appendix U, future).

## 13.7 Enterprise-Application-Suite IAM

SAP Cloud Identity Services + SAP Joule (Appendix AK, future); Workday Identity + Workday Illuminate (Appendix AL, future).

## 13.8 Agentic-Identity-Native Developer-Auth Platforms

WorkOS AgentKit (Appendix V, future); Stytech agent-IAM (Appendix W, future); Descope agentic-identity (Appendix X, future); Frontegg (Appendix Y, future); Clerk (Appendix Z, future).

### 13.9 Reference SDK

The GAuth Open-Core SDK (RFC 0125 - 0129, MPL 2.0 + Foundation Additional Terms) is the natural integration target. The intended API surface is ``MandateManagementService.deriveSyntheticMandate(identitySnapshot, issuanceEvent)``. At a future version, the SDK includes the §13.A connector-slot-registry foundation.

### 13.10 Connector-Coverage Conformance Note

Conformance is per-connector. A deployer running Microsoft Entra Agent ID + Auth0 + SPIRE in production Need only implement the bridge contract for those three connectors. A deployer Is free to write its own bridge implementation for any connector and submit it to the Foundation reference connector registry per §20.

### 13.A GAuth Open-Core Reference Connector Slot Registry (Normative)

This subsection specifies the reference connector-slot-registry foundation that the GAuth Open-Core SDK (future version) realises and that any compatible Foundation-side reference operator (e.g., Gimel Auth) Must adopt. The intent is to provide a single, normatively-named integration surface against which IAM-platform adapters (Type-A) and bridge adapters (Type-B) are registered, and against which the open-core symmetry rules of §6.5 are enforced.

#### 13.A.1 The 9-Slot Registry

The reference operator Must expose the following 9 connector slots. Slots 1–7 pre-exist in the Foundation reference operator from prior normative work and are listed for completeness; \*\*slots 8 and 9 are introduced normatively at v0.7\*\*.

#	Slot identifier	Type	Open-core operator-mode at Tariff 0	Operator-mode at Tariff S/M/L
1	`pdp`	B	`null_or_user`	`gimel_or_user`
2	`oauth_engine`	B	`user_provided_required`	`gimel_or_user`

```

| 3 | `foundry` | B | `null_or_user` | `gimel_or_user` |
| 4 | `wallet` | B | `null_or_user` | `gimel_or_user` |
| 5 | `ai_governance` | B | `null_or_user` | `gimel_or_user` |
| 6 | `web3_identity` | B | `null_or_user` | `gimel_or_user` |
| 7 | `dna_identity` | B | `null_or_user` | `gimel_or_user` |
| **8** | **`identity_platform`** | **A (multi-instance)** |
`user_provided_required` | **`gimel_or_user`** |
| **9** | **`identity_bridge`** | **B (single-instance)** |
`null_or_user` | **`gimel_or_user`** |

```

### 13.A.2 Type-A (Multi-Instance) Slot — `identity\_platform`

The `identity\_platform` slot is multi-instance: the reference operator Must support concurrent registration of one adapter per externally-controlled `platformId` (e.g., `entra-agent-id-tenant-A`, `okta-workforce-tenant-B`, `spire-trust-domain-C`, `cyberark-pam-tenant-D`). Each registration Must carry: `platformId`, `cookbookAppendix` (one of A / B / C / D / E or future), `tariffTier` (O / S / M / L / G), `operatorMode` (per the matrix in §13.A.1), `conformanceDispositionHint` (one of `minimal` / `standard` / `strict` / `platform-native`), and a typed adapter conforming to the `IdentityPlatform` interface:

```

...

interface IdentityPlatform {
 observeIdentityIssuance(filter):
 AsyncIterable<IdentityIssuanceEvent>;

 observeAttributeMutation(filter):
 AsyncIterable<IdentityAttributeMutationEvent>;

 observeRevocation(filter):
 AsyncIterable<IdentityRevocationEvent>;

 introspect(identityId): IdentitySnapshot;

 healthCheck(): HealthStatus;
}
...

```

The reference operator's null implementation of `IdentityPlatform` Must fail closed on `observe` and `introspect` (returning a `failClosed()` error) per the no-mock policy of §SC9 — null adapters are placeholders, not silent successful no-ops.

The generic ``unregister(slotName)`` operation Must refuse multi-instance slots and require the caller to use the slot-specific ``unregisterIdentityPlatform(platformId)`` operation. The aggregate operations ``healthCheckAll()``, ``getStatusSummary()``, ``isSlotActive()``, and ``getNullSlots()`` Must iterate ``identity_platform`` instances individually and aggregate the results.

### 13.A.3 Type-B (Single-Instance) Slot — ``identity_bridge``

The ``identity_bridge`` slot Is single-instance and conforms to the `**`IdentityBridgeAdapter`**` interface:

```
...

interface IdentityBridgeAdapter {
 emit(envelope: SyntheticMandateEnvelope, evidence:
BridgeEvidence): BridgeEmissionResult;

 reverse(mandate: PoACredential): IdentityRegistrationResult;
 // §6.3 reverse bridge

 healthCheck(): HealthStatus;
}
...
```

The reference operator ships a default ``NullIdentityBridgeAdapter`` that records the emission attempt for telemetry but emits no synthetic mandate; deployments above Minimal Must replace it with a §6-conformant adapter. Tariff matrix per §13.A.1 row 9: open-core deployments at Tariff 0 run ``null_or_user`` (the user supplies their own bridge if they want one); paid tiers at S/M/L admit ``gimel_or_user``.

### 13.A.4 ``recordBridgeEmission()`` — the per-call metering hook

Every emission per §6.4 Must traverse a single ``recordBridgeEmission(record: BridgeEmissionMeteringRecord)`` hook on the reference operator. The hook Must enforce all three invariants of §6.5.2:

1. Throw on unknown ``platformId`` (fail closed).
2. Set ``billable = false`` when ``operatorMode = "user_self_hosted"``.
3. Set ``billable = false`` when ``tariffTier = "0"``, regardless of ``operatorMode``. If ``gimel_managed`` is observed at Tariff 0, additionally emit a reconciliation warning log.

The hook Must Not gate which checks of §5.2 run; it Must Not gate which §3.4 variants are available; it Must Not gate which §8 conformance profiles can be declared. Per §6.5.3, the tariff matrix gates **who provisions**, never **what checks run**.

### 13.A.5 Audit-event wiring

The `bridge_emission`` event of §6.4 Must be emitted into the unified GAuth audit JSON stream at every successful traversal of `recordBridgeEmission()`. The `phase2_evaluation.profile`` field of the event Must carry the applicable `ccpe-g` / ccpe-g-nci` / ccpe-g-ncp` / ccpe-g-nco` / ccpe-g-ncm`` value per §3.4. **Forward-looking allowlist hint:** the audit-event consumer Should validate the `phase2_evaluation.profile`` value against the `ccpe-g-*` allowlist; values outside the allowlist Should be flagged for §18 correction-channel review.

### 13.A.6 Conformance disposition for the reference foundation

A deployment that adopts the §13.A foundation but does not yet operate any non-null `identity_platform`` instance and continues to ship the `NullIdentityBridgeAdapter`` Is conformant only at the Minimalprofile. Operating one or more cookbook-conformant `identity_platform`` instances (per Appendices A–E) plus a §6-conformant `identity_bridge`` adapter Is the prerequisite for declaring **Standard** or higher.

## 14. Scope vs. Conformance

Being non-conformant to a §11 profile does not place a deployment outside the scope of this RFC. Scope and conformance are distinct dimensions. A vendor or implementer that uses any of the following falls under §17.1 Foundation IP coordination regardless of architectural choice:

- (a) Any field name, semantic content, or wire-level shape derived from the GiFo-RFC 0115 PoA Credential structure, including the synthetic-mandate envelope of §6.1.
- (b) Any audit-event type, event-type-specific field, or `phase2_evaluation`` record shape derived from §10.
- (c) Any non-conformance variant code from §3.4 (`ccpe-g``, `ccpe-g-nci``, `ccpe-g-ncp``, `ccpe-g-nco``, `ccpe-g-ncm``).
- (d) Any pipeline check semantics derived from §5.2; any restatement of §6.2 trigger-condition vocabulary.
- (e) Any architectural-axis terminology defined herein and not pre-existing in the IAM-platform or IETF/OIDF/W3C/CNCF reference set: Phase 1 / Phase 2; identity-bound

enforcement; bridge contract; synthetic mandate envelope; bridge boundary; Identity-PEP; catalogue-and-prescribe; Single-Credential PoA-Extension (S3); Two-Artefact Architecture (S2).

- (f) Any conformance claim that names a §8 profile.

- Any adoption of the §13.A 9-slot registry shape, the slot-type taxonomy (Type-A / Type-B), the tariff-tier identifiers (O / S / M / L), the operator-mode identifiers (`null\_or\_user` / `user\_provided\_required` / `user\_self\_hosted` / `gimel\_managed` / `gimel\_or\_user`), the `recordBridgeEmission()` hook contract, or the open-core symmetry rules of §6.5 in derivative implementations.

## 15. IANA / Registry Reservations

This RFC reserves the following identifier values:

- **Audit-trail `phase2\_evaluation.profile` value namespace prefix:** `ccpe-g-`. Specific reservations: `ccpe-g`, `ccpe-g-nci`, `ccpe-g-ncp`, `ccpe-g-nco`, `ccpe-g-ncm`.
- **Synthetic-mandate envelope media-types:** `application/vnd.gimel.gauth.poa+jwt` (JWT-encoded) and `application/vnd.gimel.gauth.poa+vc` (W3C-VC-encoded). Shared across CCPE-A / CCPE-B / CCPE-F / CCPE-G; the envelope's `phase2\_evaluation.profile` field disambiguates.
- **Bridge-emission event-type:** `bridge\_emission` per §6.4. Reserved within the unified GAuth audit JSON event-type registry.
- **Connector-slot identifiers:** `pdp`, `oauth\_engine`, `foundry`, `wallet`, `ai\_governance`, `web3\_identity`, `dna\_identity`, `identity\_platform`, `identity\_bridge`. Reserved within the GAuth Open-Core SDK connector-slot registry.
- **Slot-type identifiers:** `A` (multi-instance), `B` (single-instance).
- **Tariff-tier identifiers:** `O`, `S`, `M`, `L`, `G`. `G` Is internal-Gimel-development-only and Must coerce to `M` at lookup time per §6.5.2 (iii).
- **Operator-mode identifiers:** `null\_or\_user`, `user\_provided\_required`, `user\_self\_hosted`, `gimel\_managed`, `gimel\_or\_user`.

- **Cookbook-appendix identifiers:** `A`, `B`, `C`, `D`, `E` (further letters reserved per the §13 archetype map as appendices are published). Reserved within the §13.A `identity\_platform` registration's `cookbookAppendix` field.
- **Archetype identifiers:** the seven §13.1–§13.7 archetype labels plus the §13.8 grouping (workforce-IAM; open-source IAM; workload/machine identity; CI/workload-OIDC; cloud-provider IAM; IGA non-human / agent-identity governance; enterprise-application-suite IAM; agentic-identity-native developer-auth platforms). Reserved within the GAAuth Open-Core SDK type system per §F.1.

These reservations are recorded in the Foundation-side registry maintained at <https://github.com/Gimel-Foundation>; submission to IANA is queued as a downstream activity and is not a precondition for normative force.

## 16. Cross-RFC Anchors

Anchor	This RFC's relationship
RFC 0140 v1.2.1 §9.2	Inherits the parallel-naming convention; reserves `ccpe-g-*` prefix. Adds CCPE-G to the family taxonomy.
RFC 0117 §4	Restated in identity-bound form in §5.2. The 16-check pipeline is unchanged; check 16 (bridge-contract conformance) is the only CCPE-G-specific extension.
RFC 0115 §3.7	The mandatory multi-hop scope-narrowing rule is enforced at the bridge boundary per §6.2 trigger condition (a).
RFC 0170 v0.2 §1.4.b + Appendix A	The `com.gimel.gauth.commerce_mandate` UCP capability is the bridge target for commerce-class actions per §6.2 trigger condition (c).
RFC 0420 v0.7 §6	Informatively comparable: constrained-audit-profile is the closest sibling-RFC analogue to identity-introspection-bandwidth-constrained sub-cases.
RFC 0180 v0.9 §14	Source of the cross-Foundation exclusion register inherited at §14.1–§14.3.
RFC 0125 SDK future version	The SDK foundation realises the §13.A connector-slot-registry contract: 9-slot

registry, multi-instance `identity\_platform`, single  
`identity\_bridge`, `recordBridgeEmission()` hook with the four  
invariants of §6.5.2. MPL 2.0 + Foundation Additional Terms  
applies to SDK-derived code only. |

| NIST IR 8596 (Cyber AI Profile) | The L1 (pre-action  
enforcement) and L2 (multi-hop scope narrowing) leverage  
points apply equally to identity-bound deployments. The bridge  
contract of §6 is the operationalisation mechanism.  
Endorsement opportunity per §17.1. |

## 17. References

**Foundation references:** GiFo-RFC 0080, 0090, 0100; GiFo-RFC 0110, 0111, 0115, 0116, 0117 (GAuth core); GiFo-RFC 0125 v0.93+ (GAuth Open-Core SDK, MPL 2.0 + Foundation Additional Terms); GiFo-RFC 0130 (CCPE Pattern Catalogue); GiFo-RFC 0140 v1.2.1 (G-AGT, CCPE-A, 17 April 2026); GiFo-RFC 0150 v0.9.6 (G-PaC, CCPE-B); GiFo-RFC 0160 v0.6 (G-Com, CCPE-C); GiFo-RFC 0170 v0.2 (G-Commerce, CCPE-F); GiFo-RFC 0171 (Informational); GiFo-RFC 0180 v0.9 (CCPE-D); GiFo-RFC 0200 (GiFo Identifier); GiFo-RFC 0420 v0.7 (G-IoT, CCPE-E, 2 May 2026).

**External references:** IETF RFC 2119; IETF RFC 2753; IETF RFC 3339; IETF RFC 7523; IETF RFC 8693; IETF RFC 9396; IETF RFC 9449; IETF draft-ietf-oauth-identity-assertion-authz-grant (XAA, WG-adopted 25 Aug 2025); IETF draft-klrc-aiagent-auth (AIMS, -01 March 2026); IETF draft-oauth-transaction-tokens-for-agents (-03 January 2026); NIST IR 8596 (Preliminary Draft, December 2025); NIST IR 8259r1 (April 2026); NIST SP 800-207 (August 2020); OpenID Foundation AuthZEN WG; Microsoft Entra Agent ID — Microsoft Learn (post-Build-2026 revision); Microsoft Build 2026 — Day-2 keynote (19 May 2026); Microsoft Build 2026 — Identity for the agent era breakout (19 May 2026); Okta blog: "Okta for AI Agents is now generally available" (Srujana Puttagunta, 29 April 2026); Auth0 dev blog: "Auth0 Token Vault: Secure Token Exchange for AI Agents" (9 October 2025); SPIFFE / SPIRE — CNCF (graduated project).

### 17.1 Standards-Body Coordination Posture (Normative)

RFC 0210 is a sovereign Gimel Foundation specification. It is published under the RFC 0080 / 0090 / 0100 framework, is not contributed to and is not licensable through any other standards body, and remains under the exclusive editorial and IP control of the Gimel Foundation.

**Foundation IP — Foundation-owned.** The original value-add of this specification - including the bridge contract of §6, the synthetic-mandate-derivation semantics, the



four boundary primitives of §3.3, the NCI/NCP/NCO/NCM taxonomy of §3.4, the deployment-scenario taxonomy of §3.0a (S1/S2/S3), the Single-Credential PoA-Extension non-conformance analysis of §3.1.1, the conformance-profile categories and feature matrix of §11, the audit-event schema of §10 (and its `bridge\_emission` event type), the cross-RFC anchor table of §16, the §13.A 9-slot connector-registry shape, the slot-type / tariff-tier / operator-mode taxonomies, and the open-core symmetry rules of §6.5, etc. - is owned by the Gimel Foundation. RFC 0210 cites and consumes upstream substrates published by adjacent standards bodies as building blocks; it does not transfer or co-license Foundation IP to those bodies.

### 17.1.1 Adjacent Bodies — Cite-as-Upstream-Substrate

OpenID Foundation (AuthZEN PDP/PEP separation; FAPI 2.0; OIDC); IETF OAuth WG (DPoP, RAR, Token Exchange, XAA, AIMS, Transaction-Tokens-for-Agents, GNAP, Step-Up); W3C Verifiable Credentials WG (VC Data Model 2.0; VC-JWT); CNCF / SPIFFE Steering Committee (SPIFFE / SVID); OASIS (XACML — adjacent at the Runtime-PEP layer); Anthropic MCP and Google A2A communities (cross-referenced through GiFo-RFC 0160).

### 17.1.2 Adjacent Bodies — Regulation

NIST IR 8596 workshop cascade (goal: 1st-tier Informative Reference); EU AI Office / ENISA (regulatory anchoring of the CCPE-G architectural model and the bridge-contract operational mechanism).

## 18. Correction Channel

Corrections, clarifications, and additions Should be submitted via:

- GitHub Issues at <https://github.com/Gimel-Foundation/> under the Repository of GiFo-RFC 0210 (preferred for substantive technical content)
- E-mail to [info@gimelid.com](mailto:info@gimelid.com) (preferred for sensitive or vendor-coordinated submissions)

The Foundation Architecture Working Group commits to a reasonable acknowledgment cycle for all substantive submissions and to incorporation in the next-published revision (or to a written response declining incorporation with stated reasons).

## 19. Open Issues

- a) **Reverse bridge** (§6.3): the Mandate → Identity translation direction is non-trivial in current production deployments. A future version should specify a normative reverse-bridge contract.
- b) **RFC 0125 – 129 SDK extension**: implement  
`MandateManagementService.deriveSyntheticMandate(identitySnapshot, issuanceEvent)` . Foundation status: §13.A connector-slot-registry foundation closed; `deriveSyntheticMandate` implementation queued as next SDK milestone.
- c) **Additional cookbook appendices** (Appendix F: IBM Security Verify; J: Keycloak; K: WSO2; L: HashiCorp Vault + Boundary; P: AWS IAM Identity Center + Bedrock AgentCore Identity; Q: Google Cloud IAM + Agentspace; R: SailPoint; S: Saviynt; V: WorkOS AgentKit; W: Stytych; X: Descope; etc.). Continued through future versions.
- d) **Appendix N — NCO-to-Conformant Migration Cookbook**. NCO is the dominant production starting state per §3.4.3; a step-by-step migration cookbook covering principal-delegation event capture, directory-attribute back-fill, and bridge-emission bootstrap will be published as a dedicated appendix.

\* \* \*

## Appendix A — Microsoft Entra Agent ID Cookbook (Preliminary)

### A.1 Scope and Posture

Microsoft Entra Agent ID is a Public-Preview surface inside Microsoft Entra ID introducing an agent-as-first-class identity object alongside user / group / application / service-principal. **Object type:** sibling to user / group / application / service-principal. **Identifier shape:** Microsoft Graph object identifier. **Authority encoding:** Conditional Access policies + application-side scopes + Microsoft Graph permissions delegated to the agent identity at issuance. **Credential shape:** bearer access token with Continuous Access Evaluation (CAE), unchanged at the post-Build-2026 verification. Microsoft Build 2026 did not adopt a sender-constrained credential shape (DPoP, mTLS, X.509-SVID); DPoP roadmap-level signal deferred beyond GA. **Audit surface:** Microsoft Purview.

### A.2 Three-Service Mapping

CCPE-G Service	Microsoft Entra realisation
Directory	Microsoft Entra ID directory; agent identity stored as sibling to user / group / application / service-principal.
Authority-Surface	Microsoft Graph API; Entra admin centre; Conditional Access policy editor; application-registration surface.
Runtime-PEP	Microsoft Entra Conditional Access at token-issuance + downstream resource-server validation. The natural Identity-PEP is the layered Foundation-side wrapper that translates Conditional Access output into RFC 0117 PERMIT/DENY/CONSTRAIN.

### A.3 Boundary-Primitive Mapping

Primitive	Microsoft Entra realisation
<code>`identity_issuance`</code>	Microsoft Graph <code>`POST /agents`</code> (Public-Preview endpoint). Conditional Access policy assignment at issuance encodes initial scope.
<code>`identity_attribute_mutation`</code>	Microsoft Graph <code>`PATCH /agents/{id}`</code> for attribute writes; Conditional Access policy

edits for scope changes. Per-attribute decomposition supported in Microsoft Graph audit surface. |

| ``identity_revocation`` | Microsoft Graph ``DELETE`` `/agents/{id}`` for hard revocation; "disable user" semantics for soft revocation; Conditional Access "block all" assignment for emergency revocation. |

| ``identity_introspection`` | Microsoft Graph ``GET`` `/agents/{id}`` at the Identity-PEP layer. The ``directory_etag`` analogue is the Microsoft Graph ``@odata.etag`` on the agent identity object. |

## A.4 Bridge Contract Mapping

The synthetic mandate envelope is derived by a Foundation-side bridge service that consumes Microsoft Graph subscriptions on the agent identity object (for ``identity_issuance`` and ``identity_attribute_mutation`` events) and emits synthetic mandate envelopes on demand at the bridge boundary. **Trigger conditions** of §6.2 map to: (a) sub-agent actions across Entra Agent ID identity-to-identity delegation chains; (b) cross-platform actions where the downstream is non-Microsoft (Okta, Auth0, AWS IAM, GCP IAM); (c) commerce-class actions per RFC 0170 v0.2; (d) downstream-consumer-requested envelopes via ``Accept: application/vnd.gimel.gauth.poa+jwt``. The bridge-emission audit event is emitted into the Microsoft Purview audit pipeline alongside Microsoft Graph subscription source events, with ``bridge_evidence`` referencing the Microsoft Graph ``@odata.etag``.

The Foundation-side bridge service Should be registered against the §13.A ``identity_platform`` slot as a per-tenant instance with ``platformId`` = "entra-agent-id-tenant-<tenantId>" and ``cookbookAppendix`` = "A"; the bridge-emission pipeline consumes the §13.A ``identity_bridge`` slot.

## A.5 Build-2026-Update

Disposition: **no material architectural change**. Microsoft Entra Agent ID remains in Public Preview; GA timeline signalled for Microsoft Ignite 2026 (November 2026). Credential shape: bearer access token with CAE, unchanged. No Microsoft-authored IETF / OpenID Foundation draft emerged in the Build-2026 window. No new Microsoft Graph multi-hop delegation primitive introduced. No Entra Agent ID-attributable patent filings surfaced via US PAIR / EP Espacenet. v0.1-conformant deployments require no remediation under this version; it carries this finding forward unchanged.

## Appendix B — Okta Workforce Identity Cloud + Okta for AI Agents + Auth0 + Auth0 Token Vault Cookbook (Preliminary)

### B.1 Scope and Posture

Okta operates two adjacent identity-bound IAM surfaces converging onto a single agent-identity model: Okta Workforce Identity Cloud (anchored on Okta Universal Directory + Okta for AI Agents, GA 29 April 2026) and Auth0 (Customer Identity Cloud + Token Vault + Actions + FGA, Zanzibar-derived). Workforce side = Authority-Surface for workforce-anchored agents; Auth0 side = Authority-Surface for customer-anchored agents and the agent-as-Auth0-resource pattern. Sender-constrained credentials available at the wire level (Okta DPoP-bound; Auth0 JWT with optional DPoP; Auth0 Token Vault bound exchange tokens).

### B.2 Three-Service Mapping

Directory: Okta Universal Directory (workforce) + Auth0 user store + Auth0 Organizations (customer). Authority-Surface: Okta API + admin console + authorization servers (workforce) + Auth0 Management API + dashboard + Actions + FGA + Token Vault (customer). Runtime-PEP: Okta authorization servers + Universal Logout for AI Agents (workforce) + Auth0 Actions + token-exchange engine + FGA check API (customer).

### B.3 Boundary-Primitive Mapping

``identity_issuance``: Okta ``POST /api/v1/users`` + Okta-for-AI-Agents ``agentType`` attribute; Auth0 ``POST /api/v2/clients`` (agent-as-application) or ``POST /api/v2/users`` with ``app_metadata.agent = true``. ``identity_attribute_mutation``: Okta ``POST /api/v1/users/{id}`` + authorization-server policy edits; Auth0 ``PATCH /api/v2/clients/{id}`` and ``PATCH /api/v2/users/{id}`` + FGA tuple-write. ``identity_revocation``: Okta ``DELETE /api/v1/users/{id}`` + Universal Logout for AI Agents push channel; Auth0 ``DELETE /api/v2/clients/{id}`` + token-revocation + Token Vault revocation; FGA tuple deletes. ``identity_introspection``: Okta ``GET /api/v1/users/{id}`` + ``/v1/introspect``; Auth0 ``GET`` endpoints + FGA check endpoint. The ``directory_etag`` analogue is ``lastUpdated`` (Okta), ``updated_at`` (Auth0), ``last_modified`` per FGA store.

## B.4 Bridge Contract Mapping

Synthetic mandate derived by a Foundation-side bridge service consuming: (a) Okta System Log filtered to agent-identity scope; (b) Auth0 Log Streams filtered to agent-application + agent-user events; (c) Auth0 FGA tuple writes filtered to agent-principal tuples (per-action principal-binding evidence); (d) Auth0 Token Vault token-exchange events. Auth0 Token Vault token-exchange boundary is the architecturally natural single trigger point for cross-platform actions. The synthetic mandate's ``principal`` field consumes the FGA check result for the agent-principal relationship tuple as per-action principal-binding evidence — the central load-bearing role of FGA in this cookbook.

## B.5 Vendor-Acknowledgment-Update

Reserved for the post-Oktane-2026 verification pass and the Auth0 Token Vault GA window.

**Note:** Workforce-side instance Should register against §13.A ``identity_platform`` with ``platformId = "okta-workforce-tenant-<tenantId>"``; customer-side instance with ``platformId = "auth0-tenant-<tenantId>"``; both with ``cookbookAppendix = "B"``.

## Appendix C — Ping Identity / PingOne / PingOne DaVinci / ForgeRock Cookbook (Preliminary)

### C.1 Scope and Posture

Ping has, since well before the agent-identity wave, separated PDP from PEP along the OpenID Foundation AuthZEN PDP/PEP architectural axis. Post-acquisition merger with ForgeRock: PingOne Advanced Identity (rebranded ForgeRock AM/IDM/DS) supplies the identity-and-orchestration layer; the AuthZEN-aligned PDP supplies the decision layer; PingOne and ForgeRock authorization policies + DaVinci orchestration flows supply the enforcement layer. **\*\*Ping Is the single CCPE-G-cookbook subject in which the Phase-1-vs-Phase-2 split itself maps onto a pre-existing architectural seam\*\*** that the vendor has explicitly named — the AuthZEN PDP boundary Is the natural §6.2 bridge-trigger boundary.

### C.2 Three-Service Mapping

Directory: PingOne Directory + ForgeRock DS. Authority-Surface: PingOne Management API + ForgeRock IDM REST API + ForgeRock AM admin console + DaVinci flow editor; the AuthZEN-aligned PDP Is the Authority-Surface for the per-action authorization decision. Runtime-PEP: PingOne authorization policies + ForgeRock AM Authorization Policies + DaVinci orchestration flows + PingAccess / PingFederate at the federation boundary.

### C.3 Boundary-Primitive Mapping

``identity_issuance``: PingOne ``POST /environments/{env}/users`` + ForgeRock IDM ``POST /openidm/managed/agent``.  
``identity_attribute_mutation``: PingOne PATCH + ForgeRock IDM PATCH; PingOne authorization-policy edits + ForgeRock AM policy edits; DaVinci flow-edits. ``identity_revocation``: PingOne DELETE + ForgeRock IDM DELETE for hard revocation; ForgeRock AM session-termination + PingOne signOff for soft revocation; DaVinci kill-switch flow for emergency revocation.  
``identity_introspection``: PingOne GET + ForgeRock IDM GET; the AuthZEN PDP evaluation endpoint Is the natural per-action introspection boundary. The ``directory_etag`` analogue is ForgeRock IDM ``_rev`` and PingOne ``lastModified``.

## C.4 Bridge Contract Mapping

Bridge service consumes: (a) PingOne Audit filtered to agent-identity; (b) ForgeRock IDM Activity Log filtered to managed-agent objects; (c) DaVinci flow-execution events at per-step boundary; (d) the AuthZEN PDP evaluation event-stream at per-action decision boundary. **\*\*The AuthZEN PDP boundary Is the architecturally natural single trigger point\*\***; AuthZEN's pre-defined decision-context envelope simplifies synthetic-mandate-derivation logic substantially.

## C.5 Vendor-Acknowledgment-Update

Reserved for the next Ping Identity standards-bench publication cycle (notably AuthZEN WG), should public materials warrant.

**Note:** Register against §13.A ``identity_platform`` with ``platformId = "ping-pingone-env-<envId>"`` (or ``"forgerock-am-realm-<realmId>"``) and ``cookbookAppendix = "C"``.



## Appendix D — SPIFFE / SPIRE with Layered Principal-Delegation Cookbook (Preliminary)

### D.1 Scope and Posture

SPIFFE / SPIRE is, by deliberate architectural choice, a pure workload-identity substrate: SVID does not name a principal, does not carry per-action principal-binding evidence, and does not natively express multi-hop principal-narrowing. \*\*CCPE-G conformance for a SPIFFE deployment requires a layered principal-delegation surface above the SPIFFE workload identity.\*\* The Foundation's reference design for this layered surface is a separate Foundation-side service that (i) maintains a registry of principal-relationships keyed on SPIFFE ID; (ii) consumes SPIRE Server registration events; (iii) accepts principal-delegation declarations; (iv) emits the four CCPE-G boundary-primitive events; (v) at the bridge boundary derives a synthetic mandate envelope from the SVID + principal-relationship registry entry + recorded principal-delegation event. \*\*The layered surface is mandatory above Minimal, not optional.\*\*

### D.2 Three-Service Mapping.

Directory: joint of (SPIRE Server registration entries, layered-surface principal-relationship registry). Authority-Surface: SPIRE Server admin API + layered-surface principal-delegation API. Runtime-PEP: SPIRE Agent Workload API attestation is the Phase-2 attestation primitive; the Foundation-side Identity-PEP wraps the SPIRE Agent attestation result and consults the layered surface's per-action principal-relationship resolver.

### D.3 Boundary-Primitive Mapping.

``identity_issuance``: joint of SPIRE Server entry create + layered-surface ``POST /principals/{principal_id}/delegations`` (Must be correlated by SPIFFE ID and emitted within a bounded synchronisation window). ``identity_attribute_mutation``: joint of SPIRE Server entry update + layered-surface ``PATCH /delegations/{delegation_id}``. ``identity_revocation``: joint of SPIRE Server entry delete + layered-surface ``DELETE /delegations/{delegation_id}``. The Strict profile of §8.3 requires the layered-surface push channel to be live. ``identity_introspection``: joint of SPIRE Server entry show + Workload API attestation result + layered-surface ``GET /delegations/by-spiffe-id/{spiffe_id}``.

## D.4 Bridge Contract Mapping

Synthetic mandate derived from SVID (SPIFFE ID + workload-attestation context) + layered-surface principal-relationship entry + recorded principal-delegation event. SPIFFE ID → `subject`; principal → `principal` field per layered-surface registry; scope chain → per layered-surface delegation's narrowing chain. The Workload API attestation boundary is the architecturally natural single trigger point.

## Appendix E — CyberArk + Conjur + Venafi Cookbook (Preliminary)

### E.1 Scope and Posture

Post-merger, the most architecturally complete identity-bound IAM platform for the machine-identity-plus-human-supervised-session deployment archetype. CyberArk PAM + Privilege Cloud anchor the human-supervised privileged-session surface (PSM records the session, mediates the credential, supplies the session-establishment audit event); Conjur Cloud anchors the secret-management plane; Venafi TLS Protect + Venafi Trust Protection Platform anchor the X.509 machine-identity issuance plane; Venafi Firefly anchors the workload-identity issuance plane for short-lived credentials at scale. Natively supports both archetypes CCPE-G must accommodate: (i) human-supervised agent sessions and (ii) autonomous agent sessions.

### E.2 Three-Service Mapping.

Directory: CyberArk Vault + Conjur Cloud / Enterprise policy DSL stores + Venafi TLS Protect identity inventory + Venafi Trust Protection Platform certificate store. Authority-Surface: CyberArk REST (PVWA) + Privilege Cloud admin console + Conjur API + Venafi REST APIs + Venafi Firefly issuance API. Runtime-PEP: CyberArk PSM (human-supervised) + Conjur policy enforcement + Venafi Trust Protection Platform validation + Venafi Firefly just-in-time issuance + downstream-resource validator.

### E.3 Boundary-Primitive Mapping

``identity_issuance``: CyberArk ``POST /Accounts`` + Conjur policy load creating a host-identity + Venafi ``POST /vedsdk/Certificates/Request`` + Venafi Firefly issuance. The PSM session-establishment moment is also an ``identity_issuance`` event in the human-supervised-session archetype. ``identity_attribute_mutation``: CyberArk PATCH + Safe-membership changes; Conjur policy updates; Venafi renewal / re-issuance. ``identity_revocation``: CyberArk DELETE + account-disable + PSM session-termination; Conjur policy delete; Venafi CRL/OCSP; Venafi Firefly short-TTL natural expiry. ``identity_introspection``: CyberArk GET + Conjur GET + Venafi GET. The ``directory_etag`` analogue is CyberArk ``LastModified``, Conjur policy version, Venafi ``serialNumber + validFrom + validTo``.

## E.4 Bridge Contract Mapping (Dual-Trigger Pattern)

Bridge service consumes (a) CyberArk REST audit events + PSM session-event streams (human-supervised trigger feed); (b) Conjur audit events filtered to host-identity scope; (c) Venafi TLS Protect certificate-issuance / renewal events + Venafi Firefly per-issuance events (autonomous trigger feed). **\*\*Dual primary-instrumentation sites:\*\*** CyberArk PSM session-establishment boundary (human-supervised; principal naturally = session initiator) + Venafi machine-identity-issuance boundary (autonomous; principal recorded in issuance request).

## E.5 Vendor-Acknowledgment-Update

Reserved for the next CyberArk Impact event and the next Venafi Machine Identity Summit publication cycle, should public materials warrant.

**Note:** Register against §13.A `identity\_platform` with `platformId = "cyberark-pam-<deploymentId>"` (or `"venafi-tpp-<deploymentId>"` / `"conjur-cloud-<deploymentId>"` for the autonomous trigger) and `cookbookAppendix = "E"`. Dual-trigger deployments register two `identity\_platform` instances (one per trigger archetype).

\* \* \*

**Disclaimer:** ALL DOCUMENTS AND THE INFORMATION CONTAINED THEREIN ARE PROVIDED ON AN “AS IS” BASIS AND THE CONTRIBUTOR, THE ORGANIZATION THEY REPRESENT OR ARE SPONSORED BY (IF ANY), THE GIMEL FOUNDATION, AND ANY APPLICABLE MANAGERS OF ALTERNATE DOCUMENT STREAMS, DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO ANY WARRANTY THAT THE USE OF THE INFORMATION THEREIN WILL NOT INFRINGE ANY RIGHTS OR ANY IMPLIED WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE.

PRODUCT NAMES, TRADEMARKS, AND REGISTERED TRADEMARKS REFERENCED IN THIS DOCUMENT ARE THE PROPERTY OF THEIR RESPECTIVE OWNERS AND ARE USED FOR IDENTIFICATION PURPOSES ONLY. NO ENDORSEMENT IS IMPLIED.

\* \* \*